

Auditoria de Segurança - Botium Toys

Lista de verificação de controles e conformidade

Projeto acadêmico em cenário fictício - versão concluída em português

Objetivo: avaliar se a Botium Toys possui atualmente os controles de segurança listados e se segue boas práticas de conformidade aplicáveis ao cenário. As respostas foram preenchidas com base no relatório de escopo, metas e avaliação de riscos fornecido na atividade.

1. Lista de verificação de controles

Pergunta de auditoria: a Botium Toys possui atualmente este controle implementado?

Sim	Não	Controle
	X	Princípio do menor privilégio
	X	Planos de recuperação de desastres
V		Políticas de senha
	X	Separação de funções
V		Firewall
	X	Sistema de detecção de intrusão (IDS)
	X	Backups (cópias de segurança)
V		Software antivírus
V		Monitoramento manual, manutenção e intervenção em sistemas legados
	X	Criptografia
	X	Sistema de gerenciamento de senhas
V		Fechaduras (escritórios, loja e depósito)
V		Monitoramento por circuito fechado de televisão (CCTV)
V		Detecção/prevenção de incêndio (alarme, sprinklers etc.)

Observação: a existência de um controle não significa que ele esteja implementado de forma ideal. Por exemplo, a empresa possui uma política de senhas, mas os requisitos atuais são fracos.

2. Lista de verificação de conformidade

Pergunta de auditoria: a Botium Toys segue atualmente esta boa prática de conformidade?

Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI DSS)

Sim	Não	Boa prática
	X	Somente usuários autorizados têm acesso às informações de cartão de crédito dos clientes.
	X	As informações de cartão de crédito são armazenadas, aceitas, processadas e transmitidas internamente em um ambiente seguro.
	X	Existem procedimentos de criptografia de dados para proteger os pontos de contato das transações e os dados de cartão de crédito.
	X	A empresa adota políticas seguras de gerenciamento de senhas.

Regulamento Geral sobre a Proteção de Dados (GDPR)

Sim	Não	Boa prática
	X	Os dados dos clientes da União Europeia são mantidos privados e seguros.
V		Existe um plano para notificar clientes da União Europeia em até 72 horas quando seus dados forem comprometidos ou houver uma violação, conforme descrito no cenário do curso.
	X	Os dados são devidamente classificados e inventariados.
V		Políticas, procedimentos e processos de privacidade são aplicados para documentar e manter os dados adequadamente.

Nota de contexto: a atividade usa uma formulação simplificada sobre a regra de 72 horas do GDPR. Este documento preserva a lógica e a resposta esperada no cenário do curso.

3. Controles de Sistemas e Organizações (SOC Tipo 1 / SOC Tipo 2)

Verificação de boas práticas SOC

Sim	Não	Boa prática
	X	Existem políticas de acesso de usuários adequadamente estabelecidas.
	X	Dados sensíveis (PII/SPII) são mantidos confidenciais e privados.
V		A integridade dos dados garante que eles sejam consistentes, completos, precisos e validados.
V		Os dados estão disponíveis para as pessoas autorizadas a acessá-los.

4. Recomendações

A Botium Toys deve melhorar os controles de acesso, reforçar as políticas de senha, implementar criptografia e backups e adicionar um sistema de detecção de intrusão (IDS). Essas medidas ajudariam a proteger dados sensíveis, reduzir riscos de segurança e melhorar a conformidade com os requisitos do PCI DSS, GDPR e SOC.

5. Resumo das principais lacunas identificadas

- Falta de aplicação do princípio do menor privilégio e da separação de funções.
- Ausência de plano de recuperação de desastres e de backups dos dados críticos.
- Ausência de IDS e de criptografia adequada para dados sensíveis.
- Políticas de senha existentes, porém insuficientes, sem sistema centralizado de gerenciamento de senhas.
- Excesso de acesso a dados internos e informações sensíveis, afetando a confidencialidade.
- Controles físicos relevantes presentes, incluindo fechaduras, CCTV e sistemas de detecção/prevenção de incêndio.

Aviso de portfólio: este documento representa uma atividade acadêmica realizada em um cenário fictício de treinamento. Não deve ser apresentado como uma auditoria executada em uma empresa real.